

FORTIGATE NSE4

Lab 1 — Initializing FortiGate

1. Obtaining the VM Image

The FortiGate VM image is distributed through FortiCloud and requires a FortiCare account. The lab uses the KVM build, which is what EVE-NG runs.

► 1.1 FortiCloud

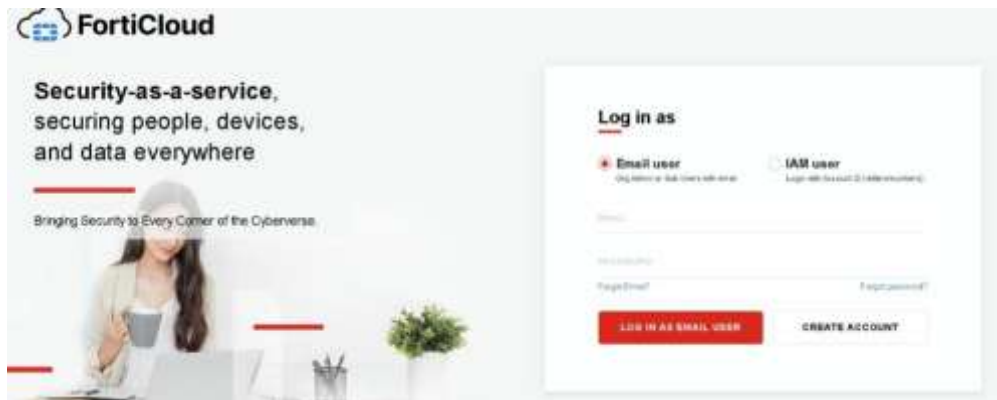


Figure 1 — FortiCloud login

Navigate to Support → VM Images, then select FortiGate as the product and KVM as the platform.

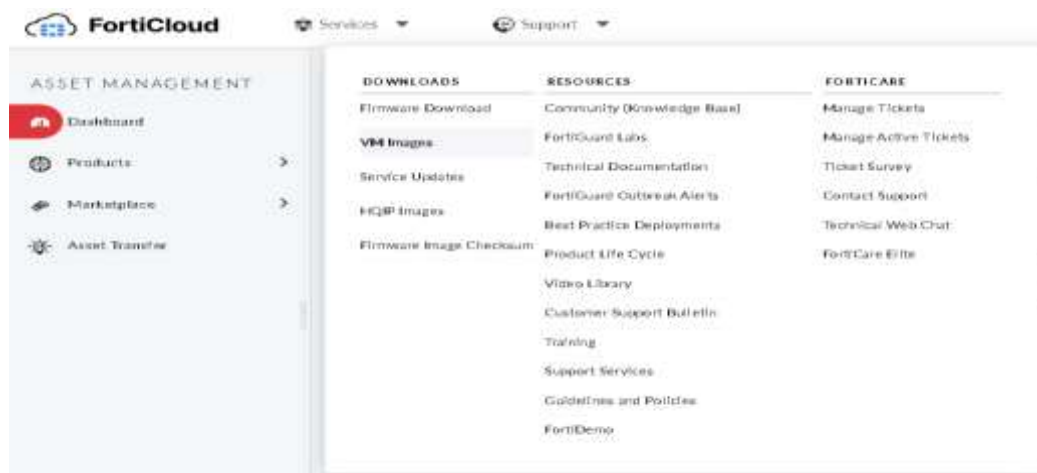


Figure 2 — The VM Images download page

► 1.2 Selecting the Right Image

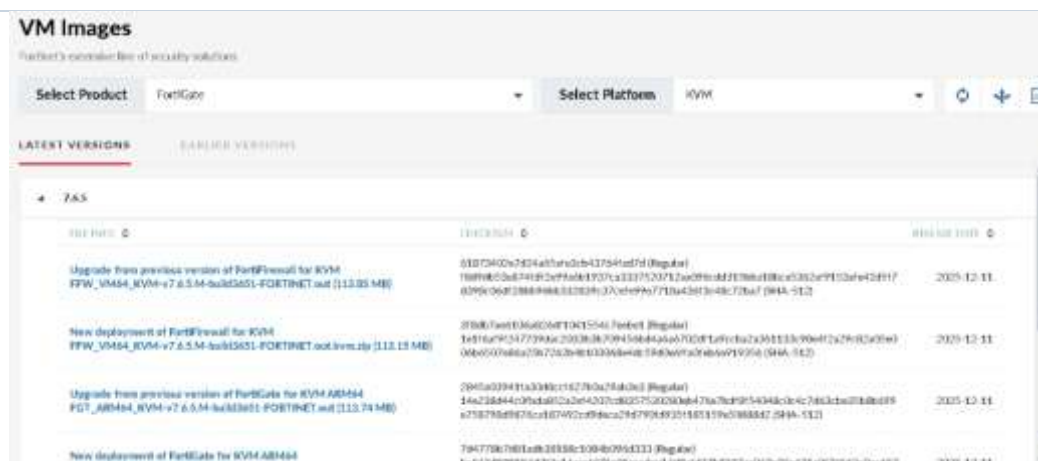


Figure 3 — FortiGate v7.6.5 KVM images with their checksums

Two builds are offered and they are not interchangeable. The “New deployment” image is a fresh install; the “Upgrade from previous version” image is only for an existing appliance. Downloading the upgrade build for a new lab produces a VM that will not boot cleanly.

Verify the checksum against the published value before deploying. A truncated download fails in ways that look like a hypervisor problem rather than a corrupt image.

► 1.3 Preparing for EVE-NG

- Rename the folder to match the EVE-NG naming convention — fortinet-7.6.5
- Convert the image to `virtioa.qcow2`
- Deploy into EVE-NG and fix permissions

2. Topology

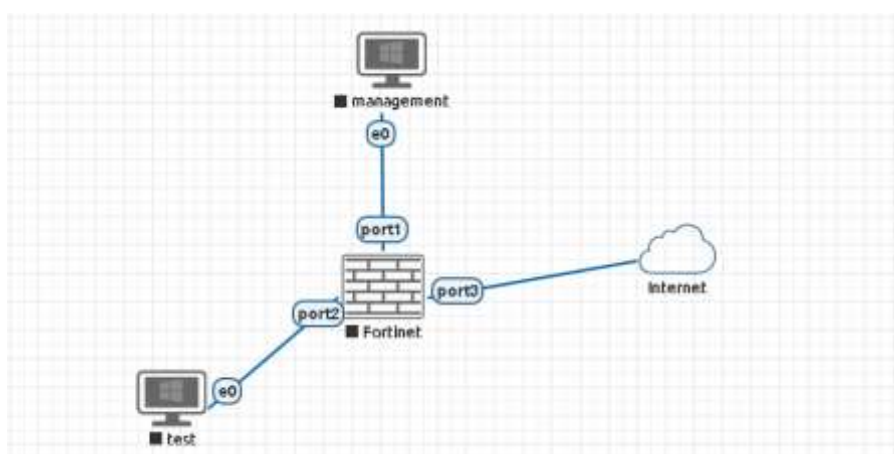


Figure 4 — Three-port topology separating management from user traffic

Port	Role	Connected to
port1	Management	Management PC

Port	Role	Connected to
port2	LAN — inside	Test PC
port3	WAN — outside	Internet cloud

Separating management from data is the structural decision in this lab. **Administrative protocols should never share an interface with user traffic** — a compromised host on the LAN should not be able to reach the firewall's own login page. This matters more in an industrial network, where the data segment often carries devices that cannot be patched or monitored.

3. Initial Login and Interface Configuration

► 3.1 First Login

Access the CLI through the EVE-NG console. The factory credentials are username `admin` with an empty password. FortiOS forces a password change immediately on first login, before anything else can be configured.

► 3.2 Management Interface

```
config system interface
  edit port1
    set mode static
    set ip 192.168.100.10/24
    set allowaccess ping https ssh http
    set alias MANAGEMENT
  next
end
```

```
Welcome!

FortiGate-VM64-KVM # config system interface

FortiGate-VM64-KVM (interface) # edit port1

FortiGate-VM64-KVM (port1) # set ip 192.168.100.10/24
Can't change dynamic IP
Command fail. Return code -651

FortiGate-VM64-KVM (port1) # set mode static

FortiGate-VM64-KVM (port1) # set ip 192.168.100.10/24

FortiGate-VM64-KVM (port1) # set allowaccess ping https ssh http

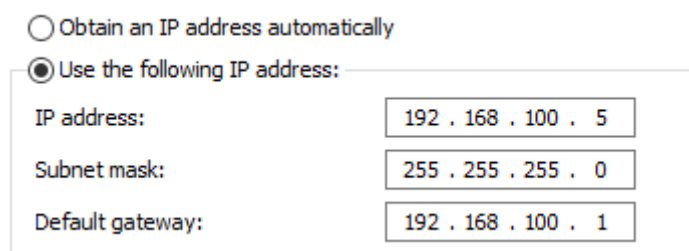
FortiGate-VM64-KVM (port1) # set alias Mangement
```

Figure 5 — CLI configuration of the management interface

A trap visible in the output: setting the IP first returns Can't change dynamic IP with return code -651. **The interface defaults to DHCP, so set mode static must come before set ip** — the error names the symptom rather than the ordering, which is why it catches people.

HTTP is enabled here for lab convenience. On a production appliance it should be removed, leaving HTTPS and SSH only.

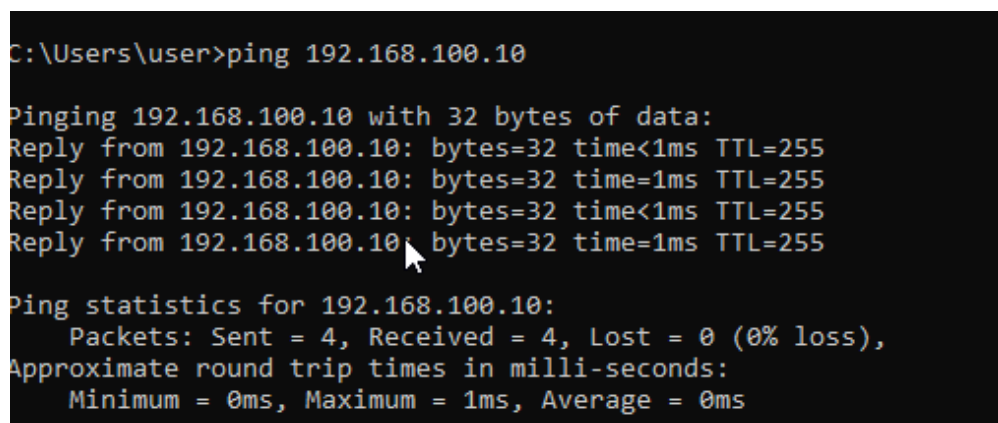
▶ 3.3 Management PC



The screenshot shows a configuration window for a management PC. At the top, there are two radio buttons: 'Obtain an IP address automatically' (unselected) and 'Use the following IP address:' (selected). Below the selected option, there are three input fields: 'IP address:' with the value '192 . 168 . 100 . 5', 'Subnet mask:' with the value '255 . 255 . 255 . 0', and 'Default gateway:' with the value '192 . 168 . 100 . 1'.

Figure 6 — Static addressing on the management PC

▶ 3.4 Verifying Reachability



```
C:\Users\user>ping 192.168.100.10

Pinging 192.168.100.10 with 32 bytes of data:
Reply from 192.168.100.10: bytes=32 time<1ms TTL=255
Reply from 192.168.100.10: bytes=32 time=1ms TTL=255
Reply from 192.168.100.10: bytes=32 time<1ms TTL=255
Reply from 192.168.100.10: bytes=32 time=1ms TTL=255

Ping statistics for 192.168.100.10:
    Packets: Sent = 4, Received = 4, Lost = 0 (0% loss),
    Approximate round trip times in milli-seconds:
        Minimum = 0ms, Maximum = 1ms, Average = 0ms
```

Figure 7 — Successful ping to the management address

Confirming Layer 3 reachability before moving to the GUI isolates any later problem to the browser or the certificate rather than to the network.

4. GUI Access and Initial Setup

▶ 4.1 Web GUI



Figure 8 — The FortiGate web login page

Reached at <https://192.168.100.10> using the credentials set during first login. The browser will warn about the certificate, because the appliance presents a self-signed one until a trusted certificate is installed.

► 4.2 Licensing

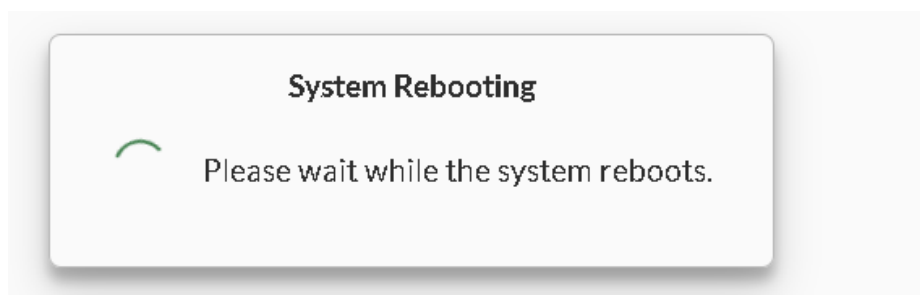


Figure 9 — The appliance rebooting after licence registration

The evaluation licence is registered with FortiCare credentials, and the appliance reboots to apply it. Until this completes, the VM runs with reduced capability.

► 4.3 Automatic Patching

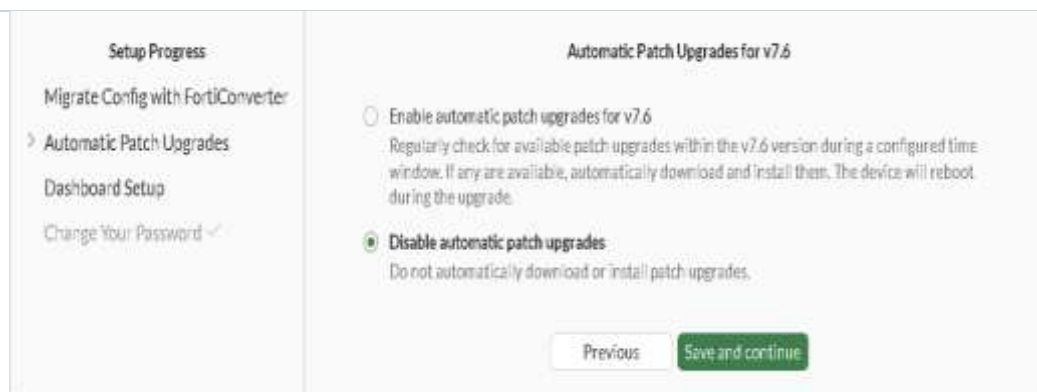


Figure 10 — Automatic patch upgrades disabled

Disabling automatic patching is a deliberate choice for industrial environments, not a convenience setting. **An unscheduled reboot during a firmware upgrade can interrupt a running process,** and the consequences of that are measured in production output rather than in downtime minutes. Patches are tested in a lab and applied in a planned maintenance window.

The trade-off is real: disabling automatic patching means a known vulnerability stays open until the next window. The decision is about controlling when the risk is taken, not avoiding it.

► 4.4 Dashboard



Figure 11 — The v7.6.5 dashboard with the appliance in NAT mode

Widget	What it reports
System Information	Hostname, serial number, firmware version, operating mode, uptime
Licenses	FortiGuard subscription status — evaluation in this lab
Virtual Machine	Allocated vCPU and RAM against the licence entitlement
CPU / Memory	Live resource graphs
Sessions	Active connection count
Administrators	Currently logged-in administrative sessions

NAT mode is the routed mode. The appliance operates at Layer 3, holding IP addresses on its interfaces and routing between them. The alternative, transparent mode, bridges segments at Layer 2 and is used where a firewall must be inserted without re-addressing the network.

► 4.5 Dashboard Customisation

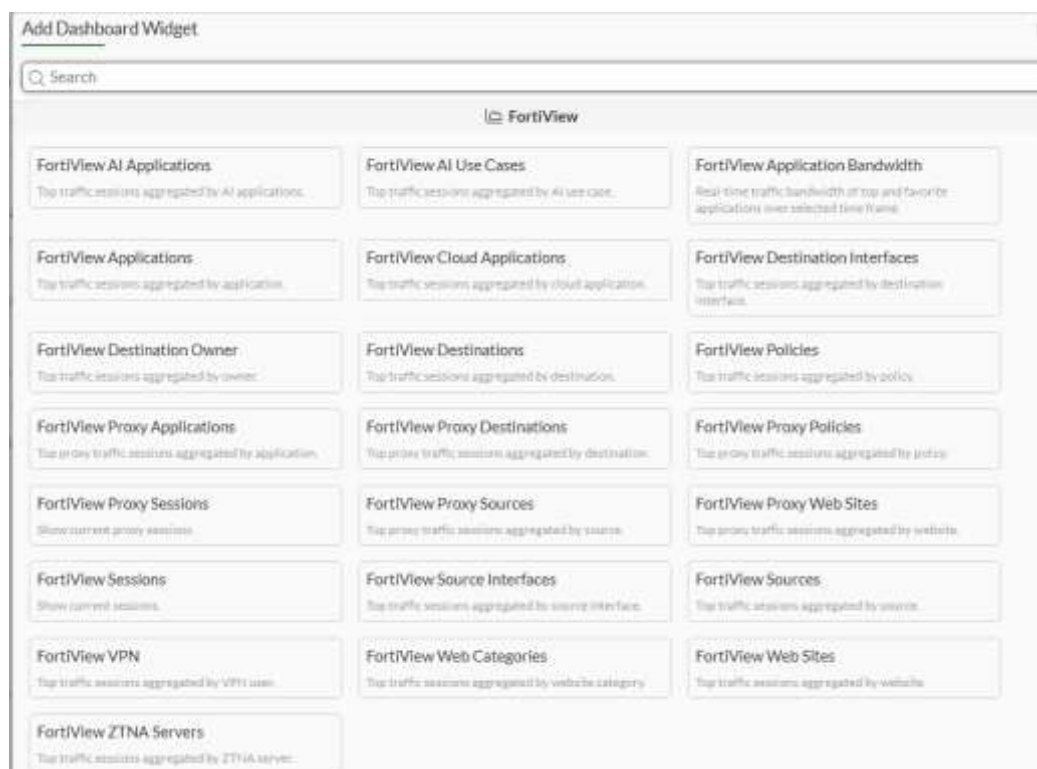


Figure 12 — The widget library, showing the FortiView analytic set

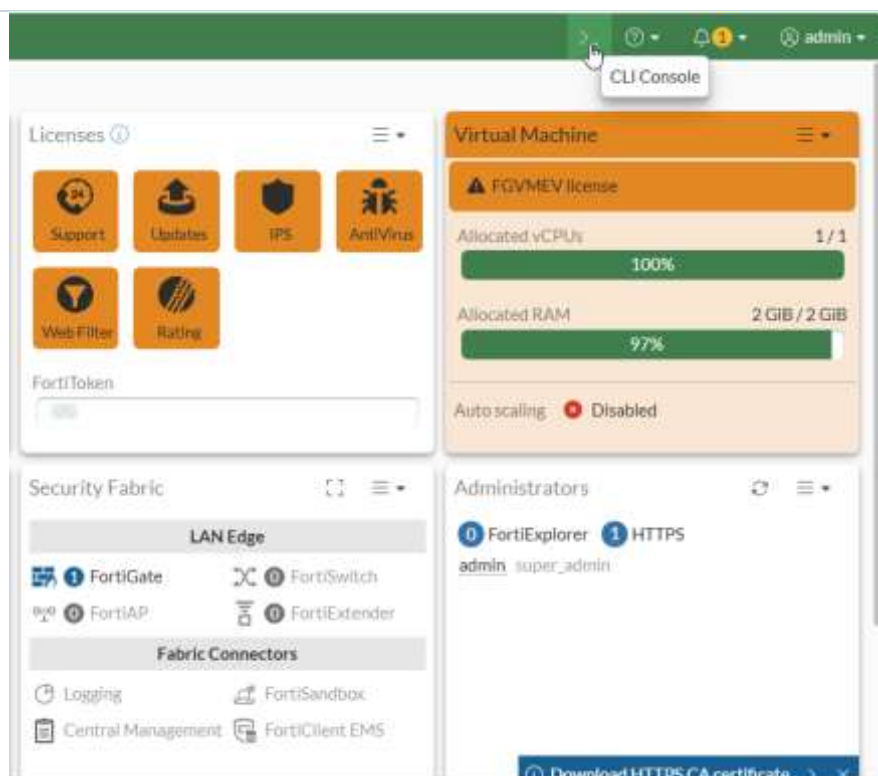


Figure 13 — CLI Console accessible directly from the dashboard

The CLI Console button opens a terminal inside the GUI. It removes the need for a separate SSH session and is the fastest route to any setting the GUI does not expose.

5. System Settings

► 5.1 Hostname

System Settings

Host name

Figure 14 — Setting a meaningful hostname

The hostname appears in logs, in HA cluster membership, and in every alert the appliance sends. A default hostname across several devices makes correlation unnecessarily difficult.

► 5.2 Time and NTP

System Time

Current system time
2026/01/18 09:04:18

Time zone
(UTC+2:00) Egypt

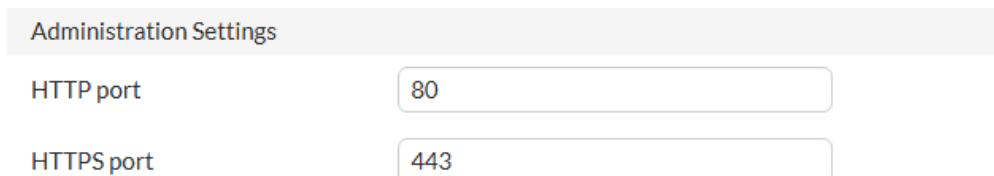
Set Time
NTP PTP Manual settings

Select server
FortiGuard Custom ⓘ

Figure 15 — Timezone and NTP synchronisation

Accurate time is a security control, not housekeeping. Without it, log timestamps cannot be correlated across devices, certificate validity checks fail or wrongly succeed, and scheduled policies fire at the wrong hours. Any investigation that spans more than one appliance depends on this being right.

► 5.3 Administration Ports

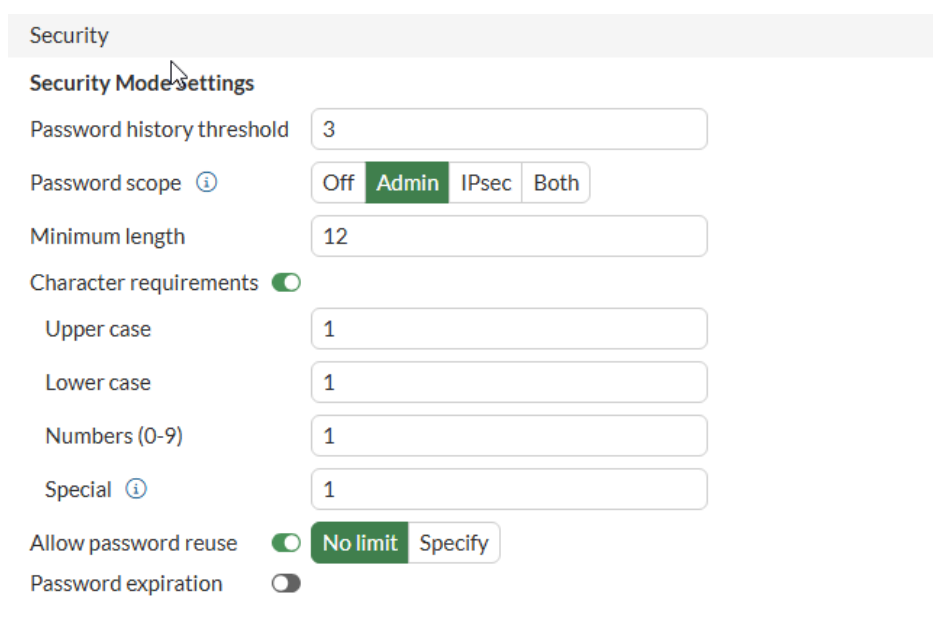


The screenshot shows the 'Administration Settings' section of the FortiGate web interface. It contains two input fields: 'HTTP port' with the value '80' and 'HTTPS port' with the value '443'.

Figure 16 — Default HTTP and HTTPS administration ports

The defaults are 80 and 443. Changing them removes the appliance from the background noise of automated scanners probing default ports, at the cost of needing the change documented — otherwise a future administrator concludes the device is unreachable.

► 5.4 Password Policy



The screenshot shows the 'Security Mode Settings' section of the FortiGate web interface. It includes the following settings:

- Password history threshold: 3
- Password scope: Admin (selected), Off, IPsec, Both
- Minimum length: 12
- Character requirements: ☒ (enabled)
- Upper case: 1
- Lower case: 1
- Numbers (0-9): 1
- Special: 1
- Allow password reuse: ☒ (enabled), No limit (selected), Specify
- Password expiration: ☐ (disabled)

Figure 17 — Password complexity enforced for administrator accounts

Setting	Value	Effect
Password history threshold	3	The last three passwords cannot be reused
Password scope	Admin	Applies to administrator accounts; can also cover IPsec pre-shared keys

Setting	Value	Effect
Minimum length	12	Length contributes more to brute-force resistance than complexity does
Character requirements	1 of each class	Upper case, lower case, numeric and special
Allow password reuse	No limit	Governed instead by the history threshold above
Password expiration	Disabled	See the note below

Leaving expiry disabled is defensible. NIST SP 800-63B no longer recommends forced periodic expiry, having found it drives predictable transformations — a trailing digit incremented each cycle — that weaken passwords rather than strengthening them. **Current guidance favours greater length, screening against known-breached passwords, and forced change only on evidence of compromise.**

► 5.5 Workflow Management

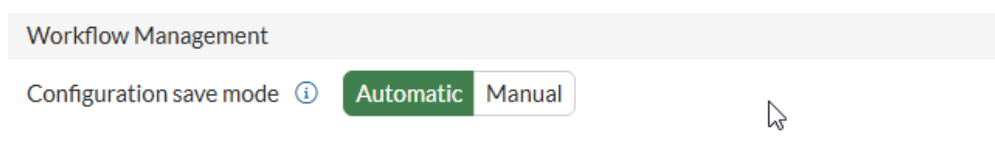


Figure 18 — Configuration save mode

Mode	Behaviour	Suited to
Automatic	Every change commits immediately. The default	Labs and single-administrator environments
Manual	Changes are staged and applied only on an explicit save, or discarded wholesale	Production change windows, where partial application would be worse than no change

► 5.6 Theme and View Settings

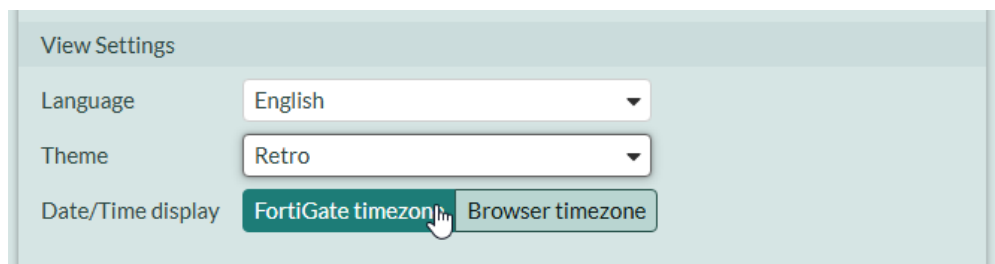


Figure 19 — Language, theme and date format

Cosmetic, with one practical use: assigning a distinct theme per appliance gives an immediate visual cue as to which device a browser tab is connected to — a cheap defence against making a change on the wrong box.

Changes in System Settings are not applied until APPLY is clicked.

6. Administrator Accounts and Profiles

► 6.1 The Default Account

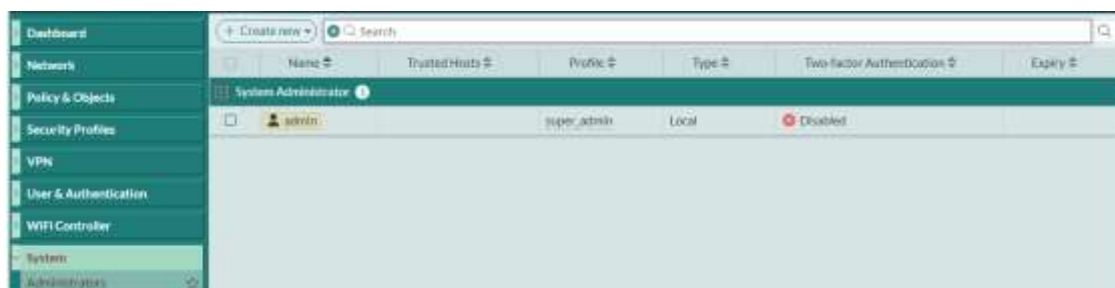


Figure 20 — The factory admin account using the super_admin profile

The default username is the problem, not the password. An attacker attempting credential stuffing against a FortiGate already knows half the credential pair — every appliance ships with the same account name. Replacing it with something non-obvious removes that advantage entirely.

► 6.2 A Replacement Super Admin

A new account is created with a non-guessable username and the same super_admin profile. FortiOS supports four authentication types.

Type	Where credentials live
Local User	On the FortiGate itself. Simple, but managed per device
Match a user on a remote server group	One named user authenticated against RADIUS, LDAP or TACACS+
Match all users in a remote server group	Any member of a directory group. The scalable option — turnover is handled in the directory rather than on every appliance
PKI group	Certificate-based, with no password to steal or guess

Username: NotGuessable

Type: Local User

- Match a user on a remote server group
- Match all users in a remote server group
- Use public key infrastructure (PKI) group

Password: [masked]

Confirm Password: [masked]

Password must conform to the following rules:

- ✓ Lower case letters
- ✓ Special characters
- ✓ Numbers (0-9)
- ✓ Upper case letters
- ✓ Minimum length

Comments: Write a comment... 0/255

Administrator profile: super_admin

Force Password Change: ☐

Figure 21 — The replacement administrator with the super_admin profile

Order of operations matters here. Create the new account, log out, log back in as that account, *then* delete the default. **FortiOS will not let you delete or rename the account you are currently logged in as**, so attempting it in the wrong order simply fails.

► 6.3 A Read-Only Profile

Auditors and analysts need visibility without the ability to change anything. A profile with every access control area set to Read provides exactly that.

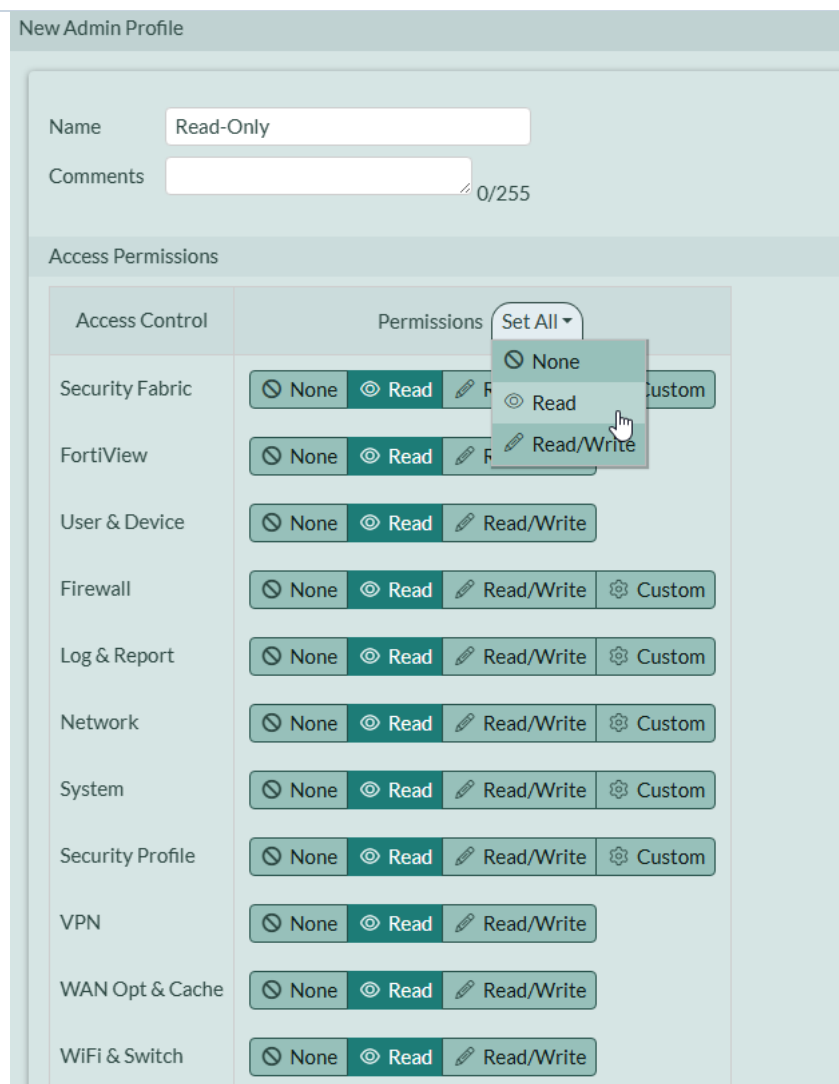


Figure 22 — A Read-Only profile with all categories set to Read

Permission	Effect
None	The area is hidden from the GUI entirely — not merely disabled
Read	Visible but not editable
Read/Write	Full access to that area
Custom	Per-sub-area granularity, available on Firewall, Log & Report, Network, System and Security Profile

Hiding rather than greying out is a deliberate design property. A restricted administrator learns nothing about what exists beyond their scope, and is not presented with controls they cannot use.

► 6.4 A Read-Only Account

New Administrator

Username: Read_Only_User

Type: Local User

Match a user on a remote server group

Match all users in a remote server group

Use public key infrastructure (PKI) group

Password: [Masked]

Confirm Password: [Masked]

Password must conform to the following rules:

- ✓ Lower case letters
- ✓ Special characters
- ✓ Numbers (0-9)
- ✓ Upper case letters
- ✓ Minimum length

Comments: Write a comment... 0/255

Administrator profile: Read-Only

Force Password Change: ☐

Figure 23 — An administrator bound to the Read-Only profile

The account references the profile rather than carrying permissions of its own, so the role is defined once and applied consistently to every account that holds it.

7. Summary

Component	Detail
FortiGate version	v7.6.5 build 3651
Platform	EVE-NG, KVM image converted to virtioa.qcow2
Operating mode	NAT — routed, Layer 3
Management interface	port1 — 192.168.100.10/24, alias MANAGEMENT
LAN interface	port2 — user and test traffic
WAN interface	port3 — internet-facing
Admin access	ping, https, ssh, http on port1 — http to be removed in production

Component	Detail
Password policy	12 characters minimum, one of each character class, history threshold 3
Automatic patching	Disabled — patches applied in planned maintenance windows
Admin profiles	super_admin, plus a custom Read-Only profile
Default account	Replaced with a non-guessable username, then deleted